

Security Scan Report

Project ID: 0c78ff09768f45a19b94032b06a93db4
Risk Level: High
Risk Score: 263

Executive Summary

The project contains multiple high-risk vulnerabilities, including issues such as SQL Injection, XSS, or Command Injection. Immediate remediation is strongly recommended.

Vulnerability Distribution

Type	Count
SQL Injection	3
Hardcoded Secret	21
XSS	21
Command Injection	7
CSRF	1

Severity Distribution

Severity	Count
High	52
Medium	1
Low	0

Detailed Findings

File	Line	Type	Severity	CWE	Priority	Business Impact
data/static/codefixes/dbSchemaChallenge_1.ts	5	SQL Injection	High	CWE-89	Fix now	Attackers may read, modify, or delete sensitive database records.
data/static/codefixes/loginAdminChallenge_1.ts	18	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginAdminChallenge_2.ts	15	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginBenderChallenge_1.ts	18	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginBenderChallenge_3.ts	15	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginBenderChallenge_4.ts	15	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginJimChallenge_2.ts	15	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
data/static/codefixes/loginJimChallenge_4.ts	18	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
frontend/src/app/data-export/data-export.component.ts	71	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/app/register/register.component.spec.ts	133	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
frontend/src/assets/private/dat.gui.min.js	1	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	13	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	23	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	33	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	35	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	39	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	40	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	41	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	44	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	48	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	49	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/dat.gui.min.js	55	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/stats.min.js	3	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/stats.min.js	4	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/three.js	310	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
frontend/src/assets/private/three.js	324	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
frontend/src/assets/private/three.js	338	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
frontend/src/assets/private/three.js	350	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
frontend/src/assets/private/three.js	11354	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/assets/private/three.js	11375	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/hacking-instructor/index.ts	126	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
frontend/src/hacking-instructor/index.ts	142	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.

File	Line	Type	Severity	CWE	Priority	Business Impact
frontend/src/hacking-instructor/helpers/helpers.ts	138	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
lib/codingChallenges.ts	76	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
lib/codingChallenges.ts	78	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
routes/login.ts	34	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	236	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	238	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	282	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	284	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	311	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	313	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	340	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	342	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	369	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	398	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/2faSpec.ts	435	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.
test/api/loginApiSpec.ts	216	SQL Injection	High	CWE-89	Fix now	Attackers may read, modify, or delete sensitive database records.
test/cypress/e2e/login.spec.ts	168	SQL Injection	High	CWE-89	Fix now	Attackers may read, modify, or delete sensitive database records.
test/cypress/e2e/profile.spec.ts	55	Command Injection	High	CWE-78	Fix now	Attackers may execute arbitrary commands and compromise the host.
test/cypress/e2e/profile.spec.ts	76	CSRF	Medium	CWE-352	Fix soon	Attackers can trigger unauthorized state changes using victim sessions.
test/files/encrypt.py	14	XSS	High	CWE-79	Fix now	Attackers can execute scripts in user browsers and steal session data.
test/server/currentUserSpec.ts	33	Hardcoded Secret	High	CWE-798	Fix soon	Leaked secrets can expose production systems and third-party accounts.

Prioritized Remediation Plan

1. [Fix now] SQL Injection: Use parameterized queries or prepared statements.
2. [Fix now] XSS: Escape output or use safe DOM methods.
3. [Fix now] Command Injection: Avoid passing raw user input to system calls.
4. [Fix soon] Hardcoded Secret: Move secrets to environment variables.
5. [Fix soon] CSRF: Use anti-CSRF tokens and validate them on every state-changing request.